

Security Scan Report

Target: <https://example.com>

Scan Date: April 26, 2026 at 09:40 UTC

Scan ID: 3085add2-9813-4a77-85bb-4d527f3e1573

0 CRITICAL

0 HIGH

0 MEDIUM

3 LOW

Executive Summary

Security scan of 'https://example.com' identified 6 raw findings, reduced to 3 unique issues after deduplication. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	6
After Deduplication	3
Critical Findings	0
High Findings	0
Medium Findings	0
Low Findings	3
Scan Duration	48.8s

Detailed Findings

[LOW] #1: Clickjacking in example.com:0

Risk Score	0.3589
Affected Location	https://example.com:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation
The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to be embedded in an iframe on a malicious site. Attackers can overlay invisible UI elements to trick users.

Code or HTTP Excerpt
1 | Response headers: X-Frame-Options = (not set)

Business Impact
Users could be tricked into performing unintended actions such as transferring funds or changing account settings.

Fix Recommendation
Rule-based recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.
LLM recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.

[LOW] #2: Missing Security Header in example.com:0

Risk Score	0.3168
Affected Location	https://example.com:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation
One or more recommended HTTP security headers are missing from the server response. Security headers instruct the browser to enable built-in protections against common web attacks.

Code or HTTP Excerpt
1 | Response headers: Strict-Transport-Security = (not set)

Business Impact
Missing security headers leave the application and its users more vulnerable to XSS, clickjacking, and data injection attacks.

Fix Recommendation

Rule-based recommendation: Configure your web server or application to send the missing security headers. Key headers include: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options (nosniff), X-Frame-Options (DENY or SAMEORIGIN), and Referrer-Policy.

LLM recommendation: Configure your web server or application to send the missing security headers. Key headers include: Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options (nosniff), X-Frame-Options (DENY or SAMEORIGIN), and Referrer-Policy.

[LOW] #3: Information Disclosure in example.com:0

Risk Score	0.2496
Affected Location	https://example.com:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt
1 | Response headers: Referrer-Policy = (not set)

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

Appendix

Deduplication Statistics

Total raw findings: 6 | After deduplication: 3 | Reduction: 50%

Scan Metadata

Scan ID	3085add2-9813-4a77-85bb-4d527f3e1573
Target	https://example.com
Timestamp	2026-04-26T09:40:49.870498+00:00
Duration	48.8s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "07090796-f1b2-4d38-86e6-6fe7e0988877",
    "title": "Clickjacking in example.com:0",
    "file": "https://example.com",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "CLICKJACKING",
    "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where users can be tricked into performing unintended actions.",
    "rule_id": "header-missing-x-frame-options",
    "confidence": 0.85,
    "cwe_id": "CWE-1021",
    "cvss_score": null,
    "code_snippet": "Response headers: X-Frame-Options = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3589,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to be vulnerable to clickjacking attacks.",
    "fix_suggestion": "Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy: frame-ancestors 'self' to restrict framing.",
    "business_impact": "Users could be tricked into performing unintended actions such as transferring funds or changing account details.",
    "raw": {
      "url": "https://example.com",
      "header": "X-Frame-Options",
      "check": "missing_header"
    }
  },
  {
    "id": "4dc548fa-bb9f-4823-8499-ad6e8945f6e0",
    "title": "Missing Security Header in example.com:0",
    "file": "https://example.com",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "MISSING_SECURITY_HEADER",
    "description": "The application does not set the Content-Security-Policy (CSP) header, which can allow attackers to inject malicious scripts into the page.",
    "rule_id": "missing-content-security-policy",
    "confidence": 0.85,
    "cwe_id": "CWE-693",
    "cvss_score": null,
    "code_snippet": "Response headers: Content-Security-Policy = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3589,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The application does not set the Content-Security-Policy (CSP) header, which can allow attackers to inject malicious scripts into the page.",
    "fix_suggestion": "Add the Content-Security-Policy header with a default policy of 'default-src: self;' to restrict the sources of content that can be loaded on the page.",
    "business_impact": "Attackers could inject malicious scripts into the page, potentially stealing user data or performing unauthorized actions.",
    "raw": {
      "url": "https://example.com",
      "header": "Content-Security-Policy",
      "check": "missing_header"
    }
  }
]
```

```

    "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow o
    "rule_id": "header-missing-strict-transport-security",
    "confidence": 0.95,
    "cwe_id": "CWE-319",
    "cvss_score": null,
    "code_snippet": "Response headers: Strict-Transport-Security = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3168,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "One or more recommended HTTP security headers are missing from the server response.
    "fix_suggestion": "Configure your web server or application to send the missing security headers. Key h
    "business_impact": "Missing security headers leave the application and its users more vulnerable to XSS,
    "raw": {
      "url": "https://example.com",
      "header": "Strict-Transport-Security",
      "check": "missing_header"
    }
  },
  {
    "id": "6a01e438-86d3-4b23-b69a-58179575bd4a",
    "title": "Information Disclosure in example.com:0",
    "file": "https://example.com",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Missing Referrer-Policy header. Sensitive information in URLs may be leaked to third-pa
    "rule_id": "header-missing-referrer-policy",
    "confidence": 0.8,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "Response headers: Referrer-Policy = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.2496,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific so
    "raw": {
      "url": "https://example.com",
      "header": "Referrer-Policy",
      "check": "missing_header"
    }
  }
]

```